

Narrativa Explicativa

Encuesta CAASM – Por qué preguntamos lo que preguntamos

1. Un inventario no es un PDF, es una historia viva

La primera parte de la encuesta se obsesiona, con toda intención, por la visibilidad de activos. No se trata de saber cuántos servidores figuran en la CMDB, sino de cuántos “viven y respiran” en el perímetro real: en la nube, en el OT, en el portátil del proveedor y en esa API que se expuso deprisa y corriendo.

Preguntar por la frecuencia de “activos sorpresa” no es un capricho literario, sino una manera suave de abordar una realidad incómoda: nuestros mapas suelen ir por detrás del terreno.

2. Higiene de seguridad: entre la teoría y la planta de producción

Las preguntas sobre controles mínimos (EDR, parches, cifrado, MFA, segmentación) buscan medir la distancia entre:

- Lo que el marco ENS, NIS2 o ISO 27001 desean ardientemente.
- Lo que la realidad operativa, presupuestaria y cultural consiente.

No queremos sólo saber si “existen políticas”, sino si los activos **críticos** viven en un nivel de protección coherente con su importancia. La ironía (“estrategia basada en la esperanza”) sirve de espejo amable para decisiones que todos sabemos que se han tomado en algún momento.

3. Exposición y riesgo: del catálogo de vulnerabilidades al universo de oportunidades del adversario

Una parte clave de CAASM no es enumerar vulnerabilidades, sino entender:

- Qué está realmente expuesto.
- A qué tipo de adversario le resulta atractivo.
- Con qué probabilidad puede explotarlo.

Por eso se pregunta si la organización se guía sólo por CVSS o si incorpora probabilidad de explotación e inteligencia de amenazas. El objetivo es detectar si la priorización está alineada con la realidad táctica del cibercrimen y la geopolítica, o si seguimos instalados en el culto al número de severidad.

4. Remediación: la métrica más honesta es el tiempo

La encuesta insiste en tiempos medios de mitigación de exposiciones críticas y altas, no sólo en “parchar vulnerabilidades”. Es la métrica que más intimida pero también la más sincera:

- Si sabemos que algo es grave y permanece abierto meses, tenemos un problema de proceso, de recursos o de prioridades.
- Si cerramos rápido lo importante pero arrastramos el resto, tenemos un problema de sostenibilidad.

Preguntar por el grado de automatización y la integración con ITSM no es tecnicismo: es diagnóstico de músculo organizativo.

5. Cumplimiento: del check-list anual a la supervisión continua

La combinación de NIS2, ENS, GDPR, DORA y compañía constituye un coro normativo exigente. La encuesta explora si:

- CAASM se ha convertido en un aliado para demostrar cumplimiento continuo.
- O si la organización sigue viviendo de auditoría en auditoría, con evidencias ad hoc.

El interés no es punitivo, sino práctico: la misma herramienta que ayuda a reducir superficie de ataque debería servir para dormir mejor la noche antes de una inspección.

6. Gobernanza: ¿es CAASM un protagonista o un secundario técnico?

En las últimas secciones preguntamos qué papel juega la información de superficie de ataque en:

- La gestión de riesgos corporativos.
- La toma de decisiones de inversión.
- La relación con terceros y autoridades.

Si CAASM sólo aparece en informes del equipo técnico, su poder transformador está infrautilizado. Si en cambio nutre decisiones de dirección, estamos ante un cambio de cultura: del “apagafuegos” al “gestor de exposición”.

7. El tono: ironía como herramienta de sinceridad

La redacción ha sido cuidada para:

- Evitar tecnicismos innecesarios para el caso.
- Introducir ligeros toques de ironía que inviten a la honestidad (“creemos en la esperanza como control compensatorio” es, en el fondo, una forma más amable de reconocer que falta automatización).

La encuesta no pretende avergonzar a nadie, sino ofrecer un espejo donde las organizaciones puedan verse con suficiente nitidez como para actuar, pero con suficiente humor como para no paralizarse.

8. ¿Qué hacer con las respuestas?

Idealmente, la organización debería:

1. Completar la encuesta de forma reflexiva, quizá con más de una persona.
2. Revisar el resultado cuantitativo (índices) y cualitativo (comentarios).
3. Identificar tres o cuatro prioridades claras:
4. Mejorar visibilidad.
5. Reducir exposición externa.
6. Acelerar remediaciones.
7. Integrar CAASM en gobierno de riesgo.
8. Repetir el ejercicio al cabo de 12-24 meses.

Si en la segunda ronda la ironía de algunas respuestas empieza a resultarnos incómoda porque ya no nos reconocemos en ella, habremos progresado.

Fin de la narrativa explicativa.